

Postra 이메일 통합 관리 플랫폼 관리자 가이드

문서 관리 정보

- 소속: AI Infra실 (AI Infra Department)
- 문서 버전: v0.20.0
- 최종 수정일: 2026년 9월 15일
- 대상: 시스템 관리자, DevOps/Infra 엔지니어, 보안 담당자

1. 아키텍처 및 소스 패키지 구성 (Architecture & Directory Layout)

Postra는 단일 바이너리 배포부터 K8s 기반 다중 노드 고가용성(HA) 아키텍처까지 확장 가능하도록 Hexagonal Architecture 포트-어댑터 패턴으로 구성되어 있습니다.

```

+-----+
|                                     |
|   cmd/postr/main.go               |
| - CLI Subcommands / Single-binary Serve Entrypoint / Graceful Shutdown |
+-----+
|
+-----+
|                                     |
|   internal/application             |
| - App Core / sync.go / accounts.go / rules.go / auth.go / oidc.go / incidents.go |
+-----+
|                                     |
+-----+
| internal/adapters |
| /secretstore      |
| - LocalStore      |
| - DBStore         |
| - Envelope AES    |
+-----+
+-----+
| internal/adapters |
| /objectstore      |
| - LocalStore      |
| - DBStore         |
| - Encrypted       |
+-----+
+-----+
| internal/adapters |
| /persistence      |
| - SQLite3 (WAL)   |
| internal/adapters |
| /pgstore          |
| - PostgreSQL      |
| - pgvector        |
+-----+

```

1.1 소스 패키지 상세 레이아웃

- `cmd/postra` : 서버커맨드 (`init` , `serve` , `mcp` , `account` , `secret` , `sync` , `search` 등) 핸들러 및 SIGTERM/SIGINT 수거 루틴
- `internal/application` : 비즈니스 유스케이스 코어 (`App` , `Sync` , `Account` , `Rule` , `Auth` , `OIDC` , `Incident`)

- `internal/domain` : 도메인 엔티티 정의 (`Message` , `MailAccount` , `SecretHandle` , `Incident` , `Job`)
 - `internal/adapters/secretstore` : AES-256-GCM Envelope 암호화 레코드 스토어 (`LocalStore` , `DBStore`)
 - `internal/adapters/objectstore` : 메일 원문 MIME 및 첨부파일 암호화 객체 스토어 (`LocalStore` , `DBObjectStore` , `EncryptedStore`)
 - `internal/adapters/persistence` : SQLite3 데이터베이스 어댑터 (WAL 모드, FK 활성화)
 - `internal/adapters/pgstore` : PostgreSQL + pgvector 인덱스 지원 어댑터
 - `internal/adapters/mailparse` : RFC822/MIME 디코더 및 `bluemonday` HTML Safe 세니타이저
 - `internal/adapters/malware` : ClamAV 및 YARA 연동 첨부파일 보안 검사 엔진
 - `internal/transport/httpapi` : REST API 핸들러 (`/api/...`) 및 API 토큰 인증 미들웨어
 - `internal/transport/spa` : Go에 포함된 React 워크스페이스 (`/app/...`)
 - `internal/transport/httpapi` : 공통 REST `/auth/*` 인증·격리 HTML/추적 전송
 - `internal/transport/mcpserver` : Model Context Protocol SSE 및 Streamable HTTP 서비스 (`/mcp`)
-

2. 배포 및 환경변수 완벽 레퍼런스 (Environment Configuration)

Postrа는 설정 파일(`config.json`) 또는 환경변수(`POSTRA_*`)를 통해 동작을 정밀하게 제어합니다.

2.1 전체 환경변수 레퍼런스 표

환경변수명	기본값	설명
<code>POSTRA_HTTP_ADDR</code>	<code>127.0.0.1:8480</code>	REST API, Web UI, MCP 통합 HTTP 바인딩 주소
<code>POSTRA_DATA_DIR</code>	<code>./data</code>	DB, 원문/첨부 객체, KEK 파일 저장 루트 디렉터리
<code>POSTRA_STORAGE_DRIVER</code>	<code>sqlite</code>	데이터베이스 드라이버 (<code>sqlite</code> 또는 <code>postgres</code>)
<code>POSTRA_DATABASE_URL</code>	-	PostgreSQL 접속 DSN (<code>postgres://user:pass@host:5432/db?sslmode=disable</code>)
<code>POSTRA_SECRET_STORE_DRIVER</code>	<code>local</code>	비밀값 저장소 드라이버 (<code>local</code> 파일 또는 <code>db</code>)
<code>POSTRA_OBJECT_STORE_DRIVER</code>	<code>local</code>	객체 저장소 드라이버 (<code>local</code> 파일 또는 <code>db</code>)
<code>POSTRA_KEK</code>	-	Base64 인코딩 32-Byte 마스터 KEK 키 (외부 주입 권장)
<code>POSTRA_ALLOW_INSECURE_MAIL</code>	<code>false</code>	평문 POP3/SMTP 허용 여부 (<code>true</code> 시 개발/테스트 용 허용)
<code>POSTRA_BOOTSTRAP_ADMIN_PASSWORD</code>	-	시스템 최초 시작 시 생성될 어드민 비밀번호
<code>POSTRA_API_TOKEN</code>	-	외부 HTTP 접근 시 헤더 인증 토큰 (<code>Authorization: Bearer <TOKEN></code>)
<code>POSTRA_WORKER_ENABLED</code>	<code>true</code>	백그라운드 리더 선출, 스케줄러, 동기화 워커 활성화 여부
<code>POSTRA_AUTO_SYNC_MINUTES</code>	<code>5</code>	메일 자동 수집 수신 주기 (분 단위, <code>0</code> 지정 시 비활성화)
<code>POSTRA_OIDC_ENABLED</code>	<code>false</code>	OIDC/OAuth2 SSO 연동 활성화 여부
<code>POSTRA_OIDC_ISSUER</code>	-	OIDC Provider Issuer URL (예: <code>https://auth.company.com/realms/main</code>)
<code>POSTRA_OIDC_CLIENT_ID</code>	-	OIDC Client ID
<code>POSTRA_OIDC_CLIENT_SECRET_REF</code>	-	암호화 SecretStore에 등록된 OIDC Client Secret 참조 키
<code>POSTRA_OIDC_AUTO_LOGIN</code>	<code>false</code>	Keycloak 세션이 있는 사용자를 로그인 화면 없이 자동 로그인 (silent SSO, <code>prompt=none</code>). 관리 화면 <code>auth.oidc.auto_login</code> 으로도 설정
<code>POSTRA_VECTOR_STORE_DRIVER</code>	<code>db</code>	의미론적 벡터 검색 드라이버 (<code>db</code> 또는 <code>milvus</code>)

환경변수명	기본값	설명
<code>POSTRA_OPENAI_API_KEY_REF</code>	-	AI 임베딩 생성용 OpenAI 호환 API Key 비밀값 참조 키

3. 어드민 계정 및 SSO 관리 (Identity & Authentication)

3.1 어드민 계정 먹등성 초기화 (`EnsureUser`)

Postrа 기동 시 `bootstrapAdmin` 프로세스가 실행되어 어드민 계정(`admin@postra.local`)을 검증합니다.

- SQLite 쿼리: `INSERT INTO users ... ON CONFLICT(login_id) DO UPDATE SET ...`
- PostgreSQL 쿼리: `INSERT INTO users ... ON CONFLICT (login_id) DO UPDATE SET ...`
- `SQLSTATE 23505 (users_pkey)` 중복 키 에러가 발생하지 않도록 먹등성(Idempotency)이 완벽히 보장됩니다.

3.2 OIDC / OAuth2 SSO 설정 절차

1. SecretStore에 OIDC Client Secret을 안전하게 저장합니다:

```
postra secret set --type oidc_client_secret --label "Keycloak SSO Client Secret"
# 출력을 통해 시크릿 참조 키(예: sec_a1b2c3d4) 확인
```

2. 환경변수 설정 후 서버를 실행합니다:

```
export POSTRA_AUTH_ENABLED=true
export POSTRA_OIDC_ISSUER="https://auth.company.com/realms/postrа"
export POSTRA_OIDC_CLIENT_ID="postra-client"
export POSTRA_OIDC_REDIRECT_URL="https://postra.company.com/auth/oidc/callback"
export POSTRA_OIDC_CLIENT_SECRET_REF="sec_a1b2c3d4"
./postra serve
```

3.3 자동 로그인 (silent SSO, `auth.oidc.auto_login`)

Keycloak(또는 ReSSO)에 이미 로그인한 사용자가 Postra를 열면 로그인 화면을 거치지 않고 바로

본 화면으로 들어가게 하는 기능입니다. 기본값은 꺼짐이며, 관리 화면(시스템 설정 → Keycloak

OIDC SSO)의 "이미 로그인한 사용자는 로그인 화면 없이 자동 로그인" 체크박스 또는

`POSTRA_OIDC_AUTO_LOGIN=true` 로 켭니다. 꺼져 있는 설치에서는 아무것도 달라지지 않습니다.

동작 방식:

- 로그인 화면이 열리면 브라우저가 `/auth/oidc/start?prompt=none` 으로 최상위 이동합니다

(숨은 iframe 이 아니므로 서드파티 쿠키 차단·프레임 정책과 무관합니다). `prompt=none` 은

제공자 화면을 절대 그리지 않습니다 — Keycloak 세션이 있으면 인가 코드가 바로 돌아와 평소처럼 로그인되고, 없으면 `error=login_required` 로 돌아옵니다. 이것은 실패가 아니라 평범한 대답이며, 서버는 `/app/login?sso=none` 으로 보내 일반 로그인 화면을 보여 줍니다.

- 서버는 `auto_login` 이 꺼져 있으면 `?prompt=none` 이 붙어 와도 조용히 평범한 로그인으로 바꿉니다. 주소를 손봐서 흐름을 바꿀 수는 없습니다.

- 깊은 링크(예: `/app/messages/...`)로 들어온 사용자는 로그인 뒤 그 자리로 돌아갑니다.

새 인증 전송의 `return_to` 는 `/app` 내부의 정규화된 경로만 받습니다. 외부 URL, 상위 경로, 로그인 반복 경로는 거부합니다.

- 거절이 아닌 **진짜 실패**(잘못된 client secret, 허용되지 않은 scope·redirect_uri, 비활성 사용자,

자동 생성 꺼짐 등)는 콜백 주소에 머무르지 않고 `/app/login?sso=error` 로 보내며, 사유는 서명된 일회용 쿠키(`postra_oidc_error`, 60초)로 전달돼 로그인 화면에 한 번만 표시됩니다.

콜백 주소(`code=...&state=...`)에 머무르면 새로고침마다 이미 쓴 코드를 다시 보내 장애 기록만

쌓이므로 그 자리를 떠나는 것입니다. 사유는 서버 로그에 남고, 토큰 교환·검증 실패는 장애 화면에도 기록됩니다.

무한 루프 방지(세 겹): (1) 한 탭 세션에 한 번만 시도 — `sessionStorage` 표시, 새 탭은 다시

시도하지만 거절 뒤 새로고침은 시도하지 않음. (2) 로그아웃 직후에는 시도하지 않음 —

로그아웃 시 억제 표시를 남기고 세션이 다시 생기면 지움. (3) 콜백이 거절을 받으면

`/app/login?sso=none` 으로 보내 주소에도 표시를 남김 — 브라우저 저장소가 비워져도 재시도하지

않음. 사생활 보호 모드처럼 저장소를 읽지 못하면 "이미 시도했다" 로 간주해 막히는 쪽으로

실패합니다. `sso=` 표시(`none` · `error` · `signed_out`)가 붙은 로그인 화면과 오류 화면, API·MCP·

헬스 경로에서는 시도하지 않습니다.

확인 절차:

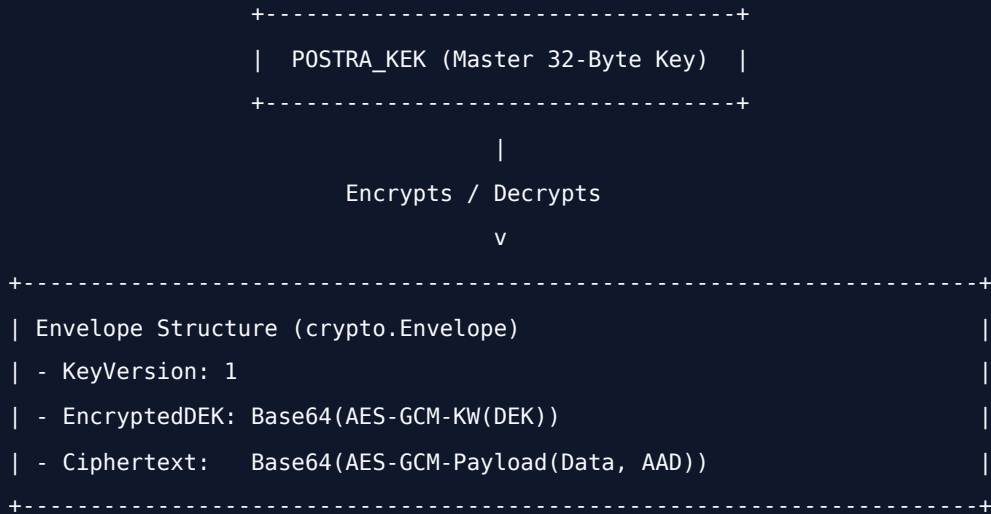
- Keycloak 에 로그인한 상태로 Postra 를 열면 로그인 화면 없이 본 화면이 뜹니다.
- 로그인하지 않은 상태로 열면 로그인 화면이 한 번에 뜨고, 새로고침을 반복해도 리다이렉트가

반복되지 않습니다.

- 로그아웃한 뒤 다시 열어도 자동으로 로그인되지 않습니다.

4. Envelope Encryption & SecretStore 구조

Postra는 사내 민감 데이터 보호를 위해 2중 봉투 암호화 메커니즘을 적용합니다.



4.1 SecretStore 암호화 레코드 스키마 (`secrets.enc.json` / `db_secrets`)

```

{
  "sec_8f9a2b1c": {
    "envelope": {
      "key_version": 1,
      "nonce": "...",
      "encrypted_dek": "...",
      "ciphertext": "..."
    },
    "owner": "admin",
    "type": "mail_password",
    "label": "업무 메일 수신 암호",
    "version": 1,
    "revoked": false
  }
}

```

4.2 KEK 로테이션 및 Self-Healing

- 비밀값 로테이션 (CLI):

```
postra secret rotate --ref sec_8f9a2b1c
```

- 자가 치유 (Self-Healing): KEK 변경 또는 파드 교체로 `secret_acquire` 에러 발생 시, Web UI 계정 편집 페이지에서 비밀번호를 다시 입력하고 저장하면 최신 KEK로 자동 재암호화 및 등록이 완료됩니다.

5. ObjectStore 백엔드 및 저장 구조 (Object Storage)

Postra는 메일 원문(RFC822 MIME) 및 첨부파일을 두 가지 어댑터 방식으로 관리합니다.

5.1 LocalObjectStore (파일 시스템 기반)

- 경로: `$POSTRA_DATA_DIR/objects/{raw|att}/xx/yyyy...`
- 파일명: SHA-256 해시값 기반의 2자 서브디렉터리 분할 저장

5.2 DBObjectStore (데이터베이스 기반)

- 테이블: `object_blobs`
- 스키마 DDL (PostgreSQL 기준):

```
CREATE TABLE IF NOT EXISTS object_blobs (  
    bucket VARCHAR(64) NOT NULL,  
    object_key VARCHAR(255) NOT NULL,  
    content_type VARCHAR(128) NOT NULL,  
    size_bytes BIGINT NOT NULL,  
    data BYTEA NOT NULL,  
    created_at BIGINT NOT NULL,  
    PRIMARY KEY (bucket, object_key)  
);
```

6. 장애 모니터링 및 이벤트 파이프라인 (Incidents & Observability)

Postra v0.10.0+는 장애 및 시스템 이벤트 추적 파이프라인을 지원합니다.

6.1 대시보드 및 REST API

- 대시보드: `http://<HOST>:8480/app/admin?category=system`
- REST API: `GET /api/incidents?severity=error&limit=50`
- JSON 응답 구조:

```
[
  {
    "id": "inc_99a8b7c6",
    "severity": "warning",
    "category": "sync_interrupted",
    "title": "POP3 Sync Interrupted",
    "detail": "Connection reset by peer during retrieve",
    "created_at": 1774345200
  }
]
```

6.2 Prometheus 메트릭 수집 (/metrics)

- `postra_sync_total{status="succeeded|failed"}` : 동기화 처리 건수
- `postra_messages_fetched_total` : 수집된 신규 이메일 수
- `postra_outbox_pending_messages` : 발송 대기 큐 크기
- `postra_attachment_blocked_total` : 악성 첨부파일 차단 횟수

6.3 방문 추적과 콘텐츠 보안 정책(CSP)

`/app/admin/tracking` 에서 추적 설정과 차단 출처를 관리합니다. 중앙 설정 API `PATCH /api/admin/configuration` 의 `values` 에 `tracking.*` 키를 넣어도 됩니다. 기본값은 꺼짐이며 브라우저에 외부 추적 코드를 로드하지 않습니다.

설정 키	기본값	적용
<code>tracking.enabled</code>	<code>false</code>	관리자 명시 활성화
<code>tracking.provider</code>	<code>none</code>	Momento·GA4·GTM·Matomo·custom
<code>tracking.custom_snippet</code>	빈 값	최대 8 KiB, 활성 provider 필수값 검증
<code>tracking.allowed_hosts</code>	빈 값	명시적으로 허용할 HTTP(S) 출처
<code>tracking.include_admin</code>	<code>false</code>	허용된 관리자 경로의 방문 측정
<code>tracking.placement</code>	<code>head</code>	격리 문서 안의 head/body 배치

추적 코드는 메인 React DOM에 삽입하지 않습니다. 별도 `/api/tracking/frame` 문서가 `sandbox="allow-scripts"` iframe으로 실행되며 `allow-same-origin`을 부여하지 않습니다. 따라서 로그인 쿠키·메일 DOM·상위 앱 storage에 접근하지 못합니다. nonce와 provider/허용 출처는 이 격리 문서의 CSP에만 적용되고 앱 전체 정책을 느슨하게 만들지 않습니다.

- 로그인·setup·오류·개인 설정·키 화면은 추적하지 않습니다. 허용된 업무 경로만 거친 정규화 형태로 전달하며 메일 ID나 검색 쿼리를 넘기지 않습니다.

- `POST /tracking/csp-report` 는 인증 없는 브라우저 보고를 제한된 크기로 받으며 차단 출처와 지시어만 메모리에 보관합니다. 문서/수집 URL의 상세 경로·검색어·비밀값은 저장하지 않습니다.
- 관리 화면의 허용·기록 지우기는 관리자 권한과 CSRF를 검사합니다. 임의 JavaScript 출처는 거부합니다.
- Momento 프록시 `/momento/*` 는 고정된 관리자 수집기만으로 전달하며 Cookie/Authorization/CSRF/Referer를 제거하고 응답 Set-Cookie를 폐기합니다. 서버가 자체 수집기를 사용하더라도 조직의 방문정보 고지·보존 정책을 적용하세요.

설정은 먼저 변경 확인으로 검토하고 저장합니다. provider 필수값 누락·과대 snippet은 400으로 거부하며 저장하지 않습니다. 끈 상태의 부분 설정은 보관할 수 있습니다. 추적 화면에서 차단된 출처를 확인하고 필요한 출처만 허용하세요.

6.4 v0.20 Web/Keycloak 이전

이전 Go 템플릿 `/ui` 는 제거했습니다. 현재 운영 화면은 `/app/admin` 이며 사용자 `?category=users` , SSO `?category=auth` , AI `?category=ai` , 동기화 `?category=sync` , 장애 `?category=system` 등으로 이동합니다. 프록시는 `/app` , `/auth` , `/api` , 필요 시 `/tracking` · `/momento` 를 전달하고 공개 Host/프로토콜을 신뢰 가능한 값으로 설정하세요.

Keycloak에 새 `https://<host>/auth/oidc/callback` URI를 먼저 추가하고 Postra Redirect URL을 변경한 뒤 일반·자동 로그인·깊은 링크·로그아웃을 검증합니다. 기존 등록값은 자동 변경하지 않습니다. v0.20에서는 기존 `/ui/auth/oidc/callback` 만 307 이동하며 토큰 교환의 `redirect_uri` 는 저장된 기존값을 유지합니다. `/ui/` 와 단일 메일 북마크도 301 이전용 shim을 제공하지만 나머지 이전 경로는 404이고, 이 shim은 v1에서 제거할 예정입니다.

사용자·메일·초안·KEK는 그대로 보존합니다. 관리자도 다른 사람의 메일을 열 수 없고, 이전 소유자의 데이터 정리는 별도 관리자 purge 확인 흐름을 사용합니다. [전체 이전 안내](#)와 [기능/보안 회귀 기록](#)을 확인하세요.

7. 전체 릴리즈 이력 (Release History: v0.1.0 ~ v0.10.5)

버전	릴리즈 일자	기술 세부 구현 및 변경사항
v0.1.0	2026-07-18	MVP 최초 배포: POP3/SMTP 수발신 코어, CLI, Stdio MCP 서버, REST API 기초
v0.2.0	2026-07-18	CGO-Free 정적 링크 바이너리 및 <code>scratch</code> 기반 Docker 샌드박스 이미지 빌더 구축
v0.3.0	2026-07-18	IMAP 수신 어댑터 추가, Prometheus <code>/metrics</code> 프로비저닝, 초기 Web UI 반영
v0.3.1	2026-07-18	<code>/healthz</code> Liveness/Readiness 헬스 체크, 검색 결과 커서 페이지네이션 구현
v0.4.0	2026-07-23	3단 반응형 Web UI 개편 및 <code>bluemonday</code> 보안 HTML 세니타이저 연동
v0.4.1	2026-07-23	REST, Web UI, Streamable HTTP MCP 서비스를 <code>8480</code> 단일 TCP 포트로 통합 바인딩
v0.5.0	2026-07-23	<code>References</code> / <code>In-Reply-To</code> RFC822 헤더 기반 대화 스레드 자동 추적 및 그룹핑
v0.5.1	2026-07-23	자동 수신 규칙 엔진 (<code>RuleEngine</code>) 구현 (삭제, 라벨링, Snooze, 중요 표시)
v0.5.2	2026-07-23	ClamAV / YARA 룰 기반 첨부파일 악성 코드 실시간 검사 및 차단 로깅
v0.6.0	2026-07-23	수신 소켓 타임아웃 옵션 및 대용량 메일 수집 DB 커밋 배치 성능 최적화
v0.7.0	2026-07-23	PostgreSQL DSN 연동 (<code>POSTRA_STORAGE_DRIVER=postgres</code>), 수집 실시간 UI 인디케이터
v0.8.0	2026-07-24	MCP RBAC 권한 제어, IMAP IDLE 수신, RRF 하이브리드 검색 및 Milvus 벡터 DB 연동
v0.8.1	2026-07-24	로고/파비콘 에셋 정적 라우팅 및 Web UI 브랜드 스타일링 반영
v0.8.2	2026-07-24	어드민 재시작 시 <code>users_pkey</code> 중복 충돌(SQLSTATE 23505) 수정 (<code>EnsureUser</code> 멍등성 보장)
v0.8.3	2026-07-24	수신 워커 예외 복구 (<code>defer recover()</code>) 및 KEK 변경 시 SecretStore 자가 치유(Self-Healing)
v0.8.4	2026-07-24	메일 파싱 객체 참조 해제 및 수집 루프 메모리 가비지 컬렉션(GC) 튜닝

버전	릴리즈 일자	기술 세부 구현 및 변경사항
v0.8.5	2026-07-24	리더 선출 DB 지연 시 활성 작업 오검출 방지 (<code>RecoverStaleJobsExcept</code> 방어)
v0.9.0	2026-07-24	루프 내 <code>FreeOSMemory()</code> 제거로 OS 스레드 급사 차단, DB 암호화 SecretStore(<code>DBStore</code>) 추가
v0.9.1	2026-07-24	메일 원문 및 첨부파일 BLOB을 DB에 암호화 보관하는 <code>DBObjectStore</code> 어댑터 구현
v0.9.2	2026-07-24	<code>db_test.go</code> 자동화 테스트 구축 및 SIGTERM 수신 시 안전한 워커 Graceful Shutdown
v0.10.0	2026-07-24	장애 대시보드(<code>/ui/admin/incidents</code>) 및 장애 트래킹 REST API(<code>/api/incidents</code>) 도입
v0.10.1	2026-07-24	백그라운드 스케줄러, IDLE, 임베딩 작업 전체 2중 예외 복구 적용으로 크래시 완벽 차단
v0.10.2	2026-07-24	메모리 이상 수신 원인을 Audit Log 및 Incident에 자동 수집하는 파이프라인 탑재
v0.10.3	2026-07-24	OIDC SSO 로그인 시 기존 부트스트랩 어드민 계정과 매핑 처리 및 세션 검증 강화
v0.10.4	2026-07-24	OIDC 실패 원인 상세 표출 및 CSRF 공격 방어 하드닝
v0.10.5	2026-07-24	메일 본문 뷰어 가독성 폰트, 블루문데이 세니타이징 CSS 스타일 디자인 고도화